

MEDSECURE SAS · HEALTHTECH · SAAS · HEALTH DATA

Information Security Management System

ISMS Scope: Clause 4

Document ID	SMSI-MDS-C4-001
Version	1.0 : DRAFT
Date	Mai 2026
Auteur	Junior Abakar : GRC Consultant
Réviseur	CISO : MedSecure SAS (TBD)
Approbateur	CEO : MedSecure SAS (TBD)
Fréquence de revue	Annuelle
Prochaine révision	Mai 2027
Classification	Confidentiel : Usage interne

This document is provided for informational and educational purposes only as part of a personal GRC portfolio project. It does not constitute professional advice. MedSecure SAS is an entirely fictional organisation; any resemblance to a real entity is coincidental.

1 Purpose

This document defines the scope of the Information Security Management System (ISMS) implemented by **MedSecure SAS** in alignment with **ISO/IEC 27001:2022**. It outlines the boundaries and applicability of the ISMS, considering the organisation's context, business objectives, and relevant requirements of interested parties.

The scope ensures that information security risks are effectively identified and managed within the defined environment, supporting MedSecure SAS's commitment to maintaining the **confidentiality, integrity, and availability** of information related to its SaaS patient records management platform which processes health data classified as a **special category under GDPR Article 9**.

2 Scope Statement

The ISMS covers the **design, development, hosting and operation** of MedSecure SAS's cloud-based SaaS patient records management platform. It includes all processes, personnel, systems, infrastructure, and information assets directly involved in delivering the service:

- Development environments
- Production systems hosted on **AWS (eu-west-3 region)**
- Supporting internal tools: Slack, Jira, GitHub, Google Workspace

The scope encompasses all **45 employees** across the Paris headquarters, the Lyon office, and remote workers, as well as relevant third-party services and vendors supporting the operation and security of the platform.

3 Context of the Organisation

3.1 Internal Issues

Internal Issue	Impact on the ISMS
Small team with limited dedicated security resources (45 employees, IT team of 6)	Risk-based approach essential to prioritise control allocation effectively.
7 employees working fully remote across multiple locations	Reinforced controls required under Annex A.6.7 (teleworking) and A.8.1 (user endpoint devices).
Cloud-native SaaS architecture hosted on AWS (multi-tenant)	Data isolation, encryption in transit and at rest mandatory. Shared Responsibility Model must be documented.
Use of third-party SaaS tools (Slack, Jira, GitHub, Google Workspace)	Access control policies and data handling agreements required for all tools. Shadow IT risk must be assessed.
Security awareness gap identified among non-technical staff	Training programme required under Annex A.6.3 to reduce human risk vectors.

3.2 External Issues

Legal, Regulatory, and Contractual Obligations

MedSecure SAS operates in a heavily regulated environment. The following obligations are applicable within the current ISMS scope:

Obligation	Description	Impact on ISMS
GDPR Article 9 Special category data	Health data requiring enhanced protection, lawful basis, and DPIA.	Controls A.5.34, A.5.35: mandatory CNIL breach notification within 72 h .
HDS Certification France / ANS	Mandatory for any organisation hosting health data on behalf of healthcare providers.	Technical & organisational controls beyond ISO 27001: prerequisite for hospital contracts.
NIS 2 Directive EU 2022/2555	EU directive transposed in France (2024). MedSecure likely in scope as health-sector DSP.	Incident reporting must align with NIS 2 time-lines: reinforces Annex A.5.24–A.5.28 .
Hospital group Contractual requirement	ISO 27001:2022 and HDS certification required as precondition for contract signature (2 M€).	Primary driver for ISMS implementation: sets the 6-month deadline .

4 Interested Stakeholders

Stakeholder	Requirements & Responsibilities
CEO	Strategic leadership; primary accountable for obtaining ISO 27001 and HDS certifications within 6 months to secure the 2 M€ hospital contract.
CISO	Leads ISMS implementation and maintenance: risk management, policy development, internal audit coordination, liaison with certification body.
GRC Analyst	Governance, risk and compliance. Policy development, risk assessments, Annex A control mapping, and Statement of Applicability (SoA) maintenance.
IT Infrastructure Engineer	AWS cloud infrastructure, network configuration, access controls. Implements technical controls under the ISMS.
Software Development Team	Integrates secure development practices (Annex A.8.25–A.8.34): secure coding, vulnerability management, change management.
All Employees 45 staff	Comply with information security policies; complete mandatory awareness training. Remote staff follow additional teleworking procedures.
Amazon Web Services (AWS)	Hosts SaaS platform (eu-west-3). Physical & infrastructure security under Shared Responsibility Model. Holds ISO 27001 and SOC 2 certifications.
Hospital group clients	Expect secure, reliable platform access. Require ISO 27001 and HDS certification. Rely on health data integrity and protection from unauthorised access.
CNIL	Regulates GDPR in France. Requires record of processing activities, DPIA, and breach notification within 72 h of detection.
ANS	Governs HDS certification. Requires demonstration of technical and organisational security measures for health data hosting.

5 Document Approval

Role	Name	Date	Signature
Author	Junior Abakar: GRC Consultant	May 2026	_____
Reviewer	CISO: MedSecure SAS	TBD	_____
Approver	CEO: MedSecure SAS	TBD	_____